

Audit Log — Senior Security Architect / SOC Engineer / Reviewer Pass

Scope of this audit: every file in this repository (7 markdown files, this pass) plus the uploaded `sophos_soc_threatintel_refined__1_.md` reference document that was merged into this repo. Deliverable type is **documentation containing illustrative config/code snippets**, not a running application — so categories in the original request that assume a live codebase (Python memory leaks, SSRF, import errors, systemd unit files, cron syntax) genuinely don't apply here; this is stated explicitly rather than fabricated to fill the template. Every finding below was verified against either (a) executable validation in a sandbox, or (b) current vendor documentation retrieved during this review — not asserted from memory. Where I could not verify something, that is stated as its own finding rather than silently assumed correct.

Verification methods actually used (not just claimed):

- All 16 Sigma YAML blocks in `03-Detection-Engineering.md` parsed with PyYAML — 0 syntax errors.
 - All XML fragments across the 7 repo files parsed with Python's `xml.etree` (wrapped in a dummy root) — 0 malformed fragments.
 - All IP addresses (`192.168.56.x`) grepped across every file and cross-tabulated — scheme is internally consistent (no stray/conflicting addresses).
 - All bash blocks in the uploaded Sophos doc checked with `bash -n` — no syntax errors.
 - Wazuh decoder semantics checked against current (`documentation.wazuh.com`) decoder docs and a real troubleshooting thread with an identical structural pattern, not from memory alone.
 - Sophos syslog field format (quoting, field names, field presence) checked against the official Sophos Community sample, the SF Syslog File Guide 19.0, and two independent SIEM-vendor ingestion docs (Sekoia, Graylog) — cross-referenced for agreement, not taken from a single source.
 - Current Wazuh version/branch status checked against `wazuh.com` release notes (as of July 2026).
-

Findings, ranked by priority

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
1	sophos_soc_threatintel_refined__1_.md (uploaded)	§5.3, decoder block, lines 145-174	High	Five child decoders share the <i>same name</i> (<code>sophos-xgs</code>) and <i>same parent</i> , each trying to extract one different field via its own <code><regex>+<order></code> .	Misunderstanding of Wazuh's sibling-decoder mechanism. Wazuh's own documentation and a confirmed troubleshooting thread with an almost identical use case (multiple fields, one log line) show this is not how multi-field extraction works — same-name siblings	<code>log_component</code> and <code>status</code> — the exact two fields the document's own §0 audit log said were the "actual bug in the first draft" — are at risk of still not decoding correctly even after the claimed fix, because the fix didn't change the underlying pattern, just added a verificatio	Rebuilt as a single combined regex per log-family in <code>08-Sophos-Firewall-Integration.md</code> §4.

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
					are tried as alternatives (first match wins), not accumulated. Official guidance : combine into one regex with all capture groups.	n step around it.	
2	sophos_soc_threatintel_refined__1_.md (uploaded)	§5.4, rule 110106	High	Rule matches <code>log_component == "CLI"</code> for "authentication failure."	Real Sophos syslog samples (verified against 3 independent sources incl. Sophos's own community reply) show ordinary WebAdmin/User Portal/local auth events	The Phase 6 end-to-end test ("fail a Sophos admin login 3x from Kali") would very likely not trigger this rule, producing a false "it's broken" during the	Corrected in detection 10.18 (<code>03-Detection-Engineering.md</code>) and <code>08-Sophos-Firewall-Integration.md</code> §5.

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
					use <code>log_component="Firewall Authentication". "CLI"</code> is a distinct, narrower component (console/SSH sessions only).	actual build, or worse, a false negative that goes unnoticed.	
3	<code>sophos_soc_threatintel_refined__1_.md</code> (uploaded)	§5.3, last decoder regex	Medium	Regex expects <code>src_ip="..."</code> (quoted).	Real Sophos "Device standard" output (the format §4 of the same document explicitly tells you to select) shows <code>src_ip=10.x.x.x</code> unquoted across	The <code>srcip</code> field would fail to extract, breaking the <code>\$(srcip)</code> reference used in the rule descriptions.	Corrected regex in <code>08-Sophos-Firewall-Integration.md</code> §4 (unquoted numeric pattern).

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
					every authoritative sample found. One third-party MSP doc shows it quoted, but under a <i>different</i> syslog format setting, so it doesn't apply here.		
4	sophos_soc_threatintel_refined_1_.md (uploaded)	§5.4, rule 110103	Low (flagged, not silently fixed)	log_component == "VPN" for SSL VPN login — exact string not independently verified.	Available reference material covered Firewall Rule, Firewall Authentication, and IDP/IPS log families in enough detail to confirm	Deploying this rule unverified risks the same silent-no n-firing problem as finding #2.	Flagged explicitly as unverified in detection 10.20 — must be confirmed with your own wazuh-logtest capture before trusting it. This is

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
					field values; VPN-specific samples were not found with equal confidence.		intentionally left as an open item, not guessed at.
5	Whole project (both docs)	version references to "Wazuh 4.14"	Medium	Wazuh 5.0 was in beta (beta 2, late June 2026) with GA "expected around mid-2026" as of the most recent information found — i.e., possibly shipping around the time this project is actually built.	Documentation written against a moving target without a version-currency caveat.	Wazuh 5.0 removes the Filebeat dependency and changes the manager install path from <code>/var/ossec</code> to <code>/var/wazuh-manager</code> . Every path in this entire project (<code>ossec.conf</code> , <code>/var/ossec/int</code>	Caveat added to README.md §4 software table: verify branch at build time, adjust paths if on 5.x.

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
						egrations/..., /var/ossec/etc/decoders/...) is 4.x-specific and would be wrong on 5.x.	
6	README.md (this repo, prior turn)	§2.2 diagram	Medium	Diagram showed Windows --1514/tcp--> Ubuntu --1514/tcp--> SIEM, implying agents chain through each other.	A correction was given in chat in the prior turn but the actual file on disk was never patched — a real "said the fix, didn't ship the fix" gap.	Anyone building from the file (not the chat log) would still see the wrong topology and might try to configure agent-to-agent relaying, which Wazuh doesn't support.	Diagram replaced in README.md §2.2 (this pass) — agents now correctly shown as independent, direct, parallel connections to the manager.
7	02-Installation-and-SIEM-Set	Entire file	High	MISP — a component the	The original 22-section	A reviewer or the student	Added as new §10 in 02-Inst

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
	up.md (this repo, prior turn)			architecture (README.md §2.1) and detection 10.17 both depend on — had zero actual installation steps anywhere in the repo; it was only referenced as a VM-sizing row and a NAT-adapter note.	request's installation guide (Sections 6-9) was scoped to VM setup + Wazuh + Windows /Linux logging; MISP install was left in the originally-uploaded reference file and never re-documented in the new repo, creating a dangling dependency.	themselves, building strictly from this repo, could not actually stand up the MISP layer the README and resume bullets both claim.	allation-and-S IEM-Setup.md (this pass), including the corrected integration-script hardening steps from finding set below.
8	03-Detection-Engineering.md (this repo, prior turn)	Header + 07-Advanced-Challenges-and-Roadmap.md	Low	File header and resume bullets claimed "18" (or README	Manual counting error when the file was originally written.	Minor, but a candidate citing "18 Sigma rules" in an	Corrected to the true, recounted total of 20 (17 original + 3 new

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
		resume bullets		claimed "20+") detections; the actual enumerated list (### 10.x headers, counted programmatically) was 17.		interview who can't produce an 18th when asked loses credibility on a claim that was easy to get right.	Sophos detections added in this integration pass) everywhere the number appears.
9	sophos_soc_threatintel_refined__1_.md (uploaded)	§7.2	Informational — verified correct, not a finding	The document's own claims about verify=False and hardcoded API keys in community MISP-integration forks, and its curl -f / test -s fix, are sound practices and were	—	—	No change needed; carried forward into 02-Installation-and-SIEM-Setup.md §10.4 as-is.

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
				kept as-is in the merged version.			

Clean / verified-correct (stated explicitly so nothing is assumed silently)

- IP addressing scheme: fully consistent across all 7 files, no orphan or conflicting addresses.
- All 16 Sigma rules: valid YAML.
- All XML config fragments: well-formed.
- Cross-file **Continue to**: references: all point to files that actually exist in the repo (updated again this pass to include the new file 08).
- LSASS **GrantedAccess** mask values in detection 10.12 (**0x1010**, **0x1410**, **0x1438**, **0x143a**): consistent with widely-documented community Sysmon/Mimikatz-detection references; not independently re-derived byte-for-byte in this pass, stated here rather than silently vouched for as 100% verified.

What "done" means here

Every **High** and **Medium** finding above has a corresponding fix already applied in this same delivery (patched files + new **08-Sophos-Firewall-Integration.md**). The two **Low/flagged** items (VPN log_component, LSASS mask provenance) are intentionally left as explicit open verification steps rather than papered over with invented confidence — that distinction is the actual point of an audit log: it should tell you what to check yourself, not just what got fixed.

Pass 2 — Second full audit, after Sophos-aware content was added to files 04/05/06/07

Why a second pass exists at all: the content added to files 04–07 after Pass 1 (simulation triggers, hunting exercises, tuning examples, containment steps) was syntax-validated

(YAML/XML/bash) before delivery, but not semantically cross-checked against the rest of the ruleset the way Pass 1's findings were. This pass closes that gap — specifically, it builds an actual rule-ID dependency map (every `<rule id>` defined vs. every `<if_matched_sid>/<if_sid>` referenced) programmatically, rather than reading the XML by eye, because that's exactly the class of bug Pass 1 already proved this project was capable of shipping.

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
9	<code>03-Detection-Engineering.md</code>	Detection 10.20, rule 110111	Critical	Rule 110111 references <code><if_matched_sid>110103</if_matched_sid></code> , but rule 110103 was never defined anywhere in the delivered project — confirmed by programmatically building the full rule-ID dependency map (grep all <code><rule id="...</code>	The original uploaded reference document defined rule 110103, but it was explicitly flagged as unverified (log_component value unconfirmed) during the Sophos integration and never carried forward into the corrected decoder/rule set — the	Rule 110111 (VPN brute-force escalation) could never fire under any circumstance — not "fires incorrectly," but structurally inert, since Wazuh's <code>if_matched_sid</code> requires the referenced rule to actually exist and match first. This is a more severe	Rule 110103 now defined in <code>03-Detection-Engineering.md</code> §10.20, paired with a new <code>sophos-vpn</code> decoder in <code>08-Sophos-Firewall-Integration.md</code> §4.3.

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
				"> definitions vs. all <if_matched_sid>/<if_sid> references across every file).	reference to it in 110111 was carried forward without noticing the thing it pointed to had been dropped.	version of finding #2 (Pass 1): that one meant a rule fired on the wrong condition; this one meant a rule could not fire at all.	
10	08-Sophos-Firewall-Integration.md	§4.3 decoder	High	No decoder existed that could ever populate <code>sophos.log_component</code> for a VPN-family log line — the two children defined in Pass 1 (<code>sophos-auth</code> , <code>sophos-fwrule</code>) each	A consequence of finding #9 — once 110103 is defined, it needs decoded fields to check, and nothing was producing them for the VPN log family.	Same as #9 — without this, defining rule 110103 alone would just trade a "rule doesn't exist" bug for a "rule exists but its field will always be empty" bug.	New <code>sophos-vpn</code> child decoder added, using a deliberately loose "contains VPN" pattern rather than a guessed exact string (see file 08 for the reasoning — this is a considered

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
				hardcode a literal match on "Firewall Authentication" or "Firewall Rule" in their capture group, so neither matches a VPN log at all.			design choice, not a shortcut).
11	06-Tuning-IR-Documentation.md	§15.2, second whitelist example	Medium	The WAN-noise suppression rule matched on <code><fieldname="sophos.srczone"></code> , but no decoder captured a <code>srczone</code> field — this was flagged honestly	Same pattern as #9/#10: a rule (or in this case, a tuning example) was written against a field the decoder didn't produce yet, and the "todo" was never	The example, if copy-pasted as-is, would never match (empty/non-existent field), silently doing nothing — the exact opposite of what a tuning example	<code>sophos-fwrule</code> decoder extended to capture <code>srczone</code> ; caveat in file 06 updated to reflect it's now functional (pending zone-name verification against a real

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
				in Pass 1 as "not yet built," but never actually built.	closed out.	is supposed to teach.	captured line).
12	04-Threat-Simulation-and-Investigation.md	§11.9, Sophos auth-failure trigger	Medium	The scripted <code>curl -X POST</code> against the WebAdmin login page assumed an exact endpoint path (<code>/webconsole/webpages/login.jsp</code>) and form field names (<code>username</code> , <code>password</code>) with no CSRF token or session cookie handling — none of which were	Web admin login forms commonly require a session cookie (obtained on GET) and/or CSRF token before a POST is accepted; a bare POST without them very plausibly gets rejected before ever reaching the authentication logic, meaning	If this silently fails, a student running it would see "no alert fired" and could easily conclude their detection is broken, when actually their test stimulus never worked — wasted debugging time on the wrong layer, exactly the failure	Manual browser-based login now given as the primary, reliable method; the scripted version is kept as an explicitly unverified alternative with instructions to capture the real request via browser dev tools first.

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
				confirmed against real Sophos behavior.	it wouldn't generate the failed-auth event the test is meant to produce at all.	mode 12.1's "isolate the fault to one link in the chain" methodology exists to prevent.	
13	06-Tuning-IR-Dokumentation.md	§15.2, first whitelist example	Informational — checked, not a bug	<pre><if_sid>5712</if_sid></pre> has no corresponding <pre><rule id="5712"></pre> anywhere in this repo.	Initially flagged by the same automated dependency-map check as #9 — but 5712 is a Wazuh built-in ruleset ID (part of the default SSH/PAM rules Wazuh ships with, in the 5700s range this project's	None — this is expected. Flagged here specifically to show the automated check's raw output was reviewed and reasoned about, not blindly trusted; a naive "grep for undefined references" pass would	No fix needed.

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
					own detection 10.5 already cites), not a custom rule this project is responsible for defining.	have wrongly flagged this as identical in severity to finding #9, when they're fundamentally different (one reference is an external, pre-existing system; the other reference is a custom rule that was supposed to exist and didn't).	
14	Software Requirements table, README.md	Sophos WebAdm in port claim	Informational — verified correct	README.md §4 and 08-Sophos-Firewall-Integration.md	—	—	Confirmed against current official Sophos documentation ("Admin

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
				reference Sophos WebAdmin on port 4444.			console HTTPS port... Default: 4444") plus multiple independent community threads. No change needed — stated here because a claim being <i>checked and found correct</i> is worth recording , not just claims that turned out wrong.
15	AUDIT-LOG.md itself	Whole file, as it stood before this Pass 2 section	Low	The audit log described the state of the	An audit log that doesn't track changes made	Low direct technical impact, but undermin	This Pass 2 section is that fix.

#	File	Location	Severity	Finding	Root Cause	Impact	Fix
				project as of Pass 1, but files 04–07 were subsequently edited (Sophos simulation triggers, bonus hunts, tuning/IR additions) without the audit log being updated to reflect it.	after it was written is itself a documentation-vs-implementation mismatch — the exact category 7 issue this whole review process exists to catch.	es the credibility of the audit log as a living artifact if left stale — someone reading only this file would have an outdated picture of the project.	

Pass 2 — clean / verified

- Rule ID dependency map (all `<rule id>` vs. all `<if_matched_sid>/<if_sid>` references, built programmatically): after fixes, **zero dangling references within this project's own custom rule range** (110xxx). The one remaining "unresolved" reference (5712) is confirmed intentional — see finding #13.
- `<decoded_as>` usage: all instances reference the **parent** decoder name (`sophos-firewall`), consistent with a verified real-world Wazuh community example (SOCFortress's pfSense decoder) showing this is the correct pattern when parent and child decoder names differ — checked, not assumed.
- Re-ran full YAML/XML/bash syntax validation after all Pass 2 fixes: still 0 errors across all three categories (see final verification pass below).

Closing note on process

Findings #9–#12 exist because Pass 1's own fixes (adding new rules, new tuning examples, new simulation steps) were themselves new surface area that hadn't been through the same dependency-level scrutiny as the original content — new code written to fix bugs can introduce its own bugs, which is exactly why the instruction to "re-check entire project after every fix" and run "multiple recursive passes" matters and wasn't just procedural box-ticking here. Two passes found four real structural issues that syntax-checking alone could never have caught, because dangling rule-ID references and unpopulated decoder fields are both *individually valid XML* — they only break at the semantic, cross-file, dependency level.